

Acme Enterprise Security & Compliance Policy (SEC-REAL-001)

Document ID: SEC-REAL-001 | Version: 2026-01 | Workspace: ws_acme_corp

Section 1: Access Control & Production Authentication

Employees must use multi-factor authentication (MFA) to access production systems and customer databases. Single-factor password authentication is strictly prohibited for production environment access.

Access permissions are reviewed quarterly by department managers and security auditors. Inactive accounts are automatically disabled after 30 days of inactivity.

Administrative access requires manager approval and formal ticket authorization prior to provisioning. All elevated privileges are subject to automated audit logging.

Section 2: Data Encryption & Communication Protection

Customer data at rest is encrypted using AES-256 block ciphers across all storage volumes, databases, and persistent block devices.

Data in transit is protected using TLS 1.2 or later cryptographic protocols across all public API endpoints and internal microservice communication channels.

Encryption keys are managed in a dedicated key management service (KMS) with automatic annual key rotation and strict hardware security module (HSM) protection.

Section 3: Data Retention & Backup Management

Database backups are created daily and stored in geographically redundant backup vaults with write-once-read-many (WORM) immutability controls.

Standard backup retention is 30 days across all general infrastructure logs and system state snapshots.

Database backup retention exception specifies that production transactional database backups are retained for 90 days to meet compliance audit requirements.

Restore procedures are tested quarterly to verify disaster recovery readiness and confirm recovery point objectives (RPO).

Section 4: Incident Response & Operational Triage

Security incidents are triaged by the on-call engineer upon initial alert triggering or user report ingestion.

Confirmed incidents are escalated immediately to the security lead for containment and root cause analysis.

The service level agreement (SLA) for resolving high-severity security incidents is 4 hours from initial escalation timestamp.

Section 5: Third-Party Risk & Vendor Security

Third-party vendors and external contractors undergo mandatory annual security reviews prior to receiving access to corporate environments.

Vendor assessments evaluate SOC 2 Type II compliance reports, penetration testing summaries, and data processing agreements.